

HONOURS-LEVEL SCENARIO

ASSESSMENT (10 MARKS)

Module 28: Digital Forensics and Incident Analysis & Response

Cisco Certified CyberOps Associate (CBROPS 200-201) • Capstone Examination

ASSESSMENT SUBMISSION

Candidate 1: Thabang Nhlokoma Buthelezi
Student No: 230011908
Candidate 2: Simphiwe Mbatha
Student No: 230000110
Assessment Weight: 10 Marks Total

CRITICAL
INCIDENT

Operation "Phantom Beacon" – Core Banking Database Exfiltration

APEX FINANCIAL INFRASTRUCTURE

SEVERITY: TIER 1 / HIGH

Background Scenario: On Friday at **23:42 SAST**, the Security Operations Center (SOC) at Apex Financial Services triggered automated high-severity alerts. An internal enterprise database server (**Host: CORE-DB-01, IP: 10.140.20.15**), which houses sensitive customer identity records and cryptographic transaction ledgers, initiated periodic outbound HTTPS connections over **port 8443** to an unclassified bulletproof hosting IP (**194.26.29.112**) in Eastern Europe.

IOC EVIDENCE EDR & PROCESS INJECTION ARTIFACTS

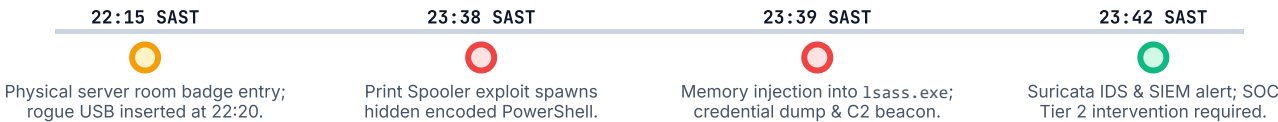
```
[23:38:12] SYSMON EVENT ID 1 (Process Create): Image:
C:\Windows\System32\WindowsPowerShell\1.0\powershell.exe
Cmd: powershell.exe -NonI -W Hidden -Enc
JABjAGwAaQBLAG4AdAA... ParentImage:
C:\Windows\System32\spoolsv.exe (Print Spooler)
[23:39:44] SYSMON EVENT ID 8 (CreateRemoteThread):
SourceImage: powershell.exe (PID: 4892) TargetImage:
C:\Windows\System32\lsass.exe (PID: 672) [23:41:05] ZEUS
/ SURICATA IDS ALERT: ET MALWARE Cobalt Strike Malleable
C2 HTTPS Beaconing detected Source: 10.140.20.15:49822
→ Dest: 194.26.29.112:8443 (Interval: 45s)
```

OPERATIONAL CONTEXT

PHYSICAL & HUMAN TELEMETRY

- Physical Security Log:** Server room badge reader logged access by a third-party facilities technician at 22:15 SAST.
- USB Event Log:** USB Mass Storage device (VID_0781 / PID_5583 SanDisk 64GB) mounted at 22:20 SAST.
- Junior Admin Proposal:** The on-duty junior sysadmin panicked upon seeing outbound traffic and grabbed the server's dual AC power cords to "pull the plug immediately".
- Database State:** Oracle Database is actively processing over 1,200 international financial settlement threads.

INCIDENT CHRONOLOGY & INVESTIGATION TIMELINE (SAST)



QUESTION 1 Order of Volatility (RFC 3227) & Live vs. Dead Forensic Acquisition

3.0 MARKS

Critique the junior administrator's decision to immediately pull the physical power cords from CORE-DB-01. With strict reference to the **RFC 3227 Order of Volatility**:

- Identify **three specific volatile forensic artifacts** that would be permanently destroyed by this action and explain their direct diagnostic value to the investigation. (1.5 Marks)
- Formulate the precise, scientifically sound technical procedure the SOC team must execute to isolate the host without terminating power or corrupting ongoing forensic extraction. (1.5 Marks)

MARKING GUIDE & HONOURS-LEVEL MODEL SOLUTION

1. Destruction of Volatile Artifacts (1.5 Marks - 0.5 per artifact):

- Physical RAM (Priority 2):** Contains the unencrypted Cobalt Strike payload, decrypted symmetric session keys (AES/TLS), and plaintext passwords harvested from lsass.exe. Pulling power wipes RAM instantly.
- Active Network Sockets & ARP/Routing Tables (Priority 2):** Ephemeral socket connections (ESTABLISHED states to 194.26.29.112:8443) proving actual data exfiltration endpoints and internal lateral scanning targets.
- Running Process Tree & Injected Threads (Priority 2):** The parent-child lineage (spoolsv.exe \$ ightarrow\$ powershell.exe \$ ightarrow\$ lsass.exe) residing in memory registers/tables, without which process-injection cannot be legally proven.

2. Proper Isolation & Live Acquisition Procedure (1.5 Marks):

- Network Isolation via EDR / Switch Port ACL:** Isolate the host at Layer 2/3 (or EDR software quarantine) to sever C2 communications while keeping operating system power on.

- **Live Volatile Memory Capture First:** Connect sterile write-blocked media or run an out-of-band RAM acquisition agent (e.g., WinPmem, DumpIt, FTK Imager CLI) to dump physical RAM to an external sanitized forensic destination.

HONOURS-LEVEL SCENARIO

ASSESSMENT (CONTINUED)

Group Candidates:
T.N. Buthelezi (230011908) & S. Mbatha
(230000110)

Module 28: Digital Forensics and Incident Analysis & Response

Mark Breakdown: Part B (2.0 Marks), Part C (3.0 Marks), Part D (2.0 Marks) •
Total: 10 Marks

QUESTION 2 Evidence Integrity, Chain of Custody & Judicial Admissibility

2.0 MARKS

During the investigation, a junior analyst performed a regular file copy (logical copy) of the Oracle database folder to a USB drive, left the drive on an open desk over the weekend, and computed its SHA-256 hash on Monday morning before handing it to legal counsel.

- Evaluate whether this digital evidence complies with the **Best Evidence Rule** and whether it is admissible in a court of law. (1.0 Mark)
- Identify two critical breaches of the **Chain of Custody** and explain how a defense attorney would exploit these procedural flaws to suppress the evidence. (1.0 Mark)

MARKING GUIDE & HONOURS-LEVEL MODEL SOLUTION

- **Violation of Best Evidence Rule (1.0 Mark):** The evidence is **inadmissible**. A logical file copy copies only indexed active files, altering the file system's Last Accessed (\$MACB\$) metadata timestamps. Under the Best Evidence Rule, the court requires the original physical drive or an exact, verified **bit-stream forensic clone** (e.g., '.E01' or '.dd' raw image) containing unallocated space, file slack, and master tables captured via a hardware write-blocker.
- **Chain of Custody Breaches (1.0 Mark):** 1) *Failure of Secure Physical Control:* Leaving the evidence unattended on an open desk over the weekend creates an unmonitored temporal gap where unauthorized tampering, malware contamination, or hardware swap cannot be refuted. 2) *Belated Hash Computation:* Generating the cryptographic hash 48 hours later rather than at the exact second of collection invalidates integrity verification. Opposing counsel can file a motion in limine to suppress the evidence due to lack of tamper-evidence.

QUESTION 3 NIST SP 800-61 Rev 2 Containment Strategy & Operational Trade-offs

3.0 MARKS

In **Phase 3 (Containment, Eradication & Recovery)** of the NIST SP 800-61 Rev 2 lifecycle:

1. Distinguish between **Short-Term Containment** and **Long-Term Containment** actions required for this banking database intrusion. (1.5 Marks)
2. The Chief Operating Officer (COO) demands that the database remain online due to \$50 million in pending transactions, while the Lead Security Analyst insists on immediate network isolation. Propose a balanced technical containment strategy that mitigates data exfiltration while satisfying institutional risk requirements. (1.5 Marks)

MARKING GUIDE & HONOURS-LEVEL MODEL SOLUTION

- **Short-Term vs. Long-Term Actions (1.5 Marks):**
 - *Short-Term:* Immediate egress filtering at the perimeter firewall dropping all traffic to destination IP 194.26.29.112; revoking compromised Service Account credentials; suspending Print Spooler service on domain controllers.
 - *Long-Term:* Full enterprise domain password reset for administrative accounts; applying zero-day patches for print spooler vulnerabilities; deploying strict internal micro-segmentation VLANs restricting database access solely to trusted app servers.
- **Balanced Operational Containment Strategy (1.5 Marks):** Implement **Targeted Egress Blackholing and Lateral Micro-Segmentation**. Rather than severing all network interfaces (which causes complete operational failure), defenders: 1) Null-route the specific external C2 IP/domain at the border firewall and border BGP/proxy level, stopping data exfiltration instantly. 2) Apply host-level firewall rules permitting only incoming SQL queries on port 1521 from the pre-authenticated Application Servers (10.140.10.0/24), while strictly denying all outbound connections and SMB/RPC lateral ports. This permits critical transaction processing while completely quarantining the threat actor.

QUESTION 4 Incident Classification (VERIS Model) & Post-Incident Continuous Improvement

2.0 MARKS

Apply the **VERIS (Vocabulary for Event Recording and Incident Sharing) 4A Model** to categorize this incident, and formulate two non-punitive, institutional remediation policies to be mandated during the 14-day **Post-Incident Lessons Learned** meeting. (2.0 Marks)

MARKING GUIDE & HONOURS-LEVEL MODEL SOLUTION

- VERIS 4A Categorization (1.0 Mark - 0.25 each):

VERIS Dimension	Incident Mapping	Justification
1. Actors	External (State-Sponsored APT) + Physical Partner	External adversary leveraging physical supply chain / technician access.
2. Actions	Physical (USB) + Malware + Hacking	Unauthorized media insertion, memory injection, and C2 command execution.
3. Assets	Server (Database: CORE-DB-01)	Core banking database hosting critical transactional ledgers.
4. Attributes	Confidentiality (Loss) & Integrity (Altered)	Credential theft from lsass.exe and unauthorized exfiltration attempt.

- Institutional Remediation Policies (1.0 Mark): 1) *Hardware Peripheral Lockdown (USB Device Control)*: Enforce Group Policy / EDR agent rules globally blocking unauthorized USB mass storage devices across all Tier 1/2 infrastructure. 2) *Two-Person Integrity Rule for Data Center Physical Access*: Mandate dual-custody physical escort and continuous CCTV monitoring for all external maintenance personnel inside core server rooms.

Assessment Component	Cisco CyberOps Syllabus Link	NIST / Legal Standard	Weight
Question 1: Volatility & Memory Acquisition	Section 28.1 (Evidence Handling)	RFC 3227 Volatility Hierarchy	3.0 Marks
Question 2: Chain of Custody & Integrity	Section 28.1 (Evidence Integrity)	Best Evidence Rule / Federal Rule 901	2.0 Marks
Question 3: Incident Containment Strategy	Section 28.2 (Incident Handling Lifecycle)	NIST SP 800-61 Rev 2 Phase 3	3.0 Marks
Question 4: VERIS & Lessons Learned	Section 28.3 (Incident Reporting Models)	VERIS 4A Framework / Post-Mortem	2.0 Marks
TOTAL ASSESSMENT ALLOCATION:			10.0 MARKS